

ffuf — Practical Tool Guide

Directory, VHost, and parameter fuzzing with extensions, filters, headers, cookies, and Burp proxying.

» [Abdullah Nasser Almsan — Personal Pentest Reference](#)

Usage note: Use inside an authorized web lab. Fuzzing can generate many requests, so tune scope and rate responsibly.

BASELINE

Understand response

FUZZ

Choose position

FILTER

fc / fs / fw

VERIFY

Check manually

Contents

1. The FUZZ rule
2. Filtering
3. VHost discovery
4. Parameter fuzzing
5. Headers / Cookies / Burp
6. Workflow

1. The FUZZ rule

ffuf needs a wordlist and a FUZZ marker at the request position you want to vary.

KALI TERMINAL — Directory discovery

```
ffuf -w [WORDLIST] -u http://[TARGET]/FUZZ
```

KALI TERMINAL — Extensions

```
ffuf -w [WORDLIST] -u http://[TARGET]/FUZZ -e .php,.txt,.html
```

2. Filtering

Filtering is the main skill that keeps thousands of responses manageable.

Option	Meaning
-fc	Filter status codes
-fs	Filter response size
-fw	Filter word count
-fl	Filter line count
-fr	Filter regex
-mc	Match status codes

KALI TERMINAL — Size-filter example

```
ffuf -w [WORDLIST] -u http://[TARGET]/FUZZ -fs [BASELINE_SIZE]
```

Take a baseline from a definitely invalid path. If every path returns 200, filter by size/words instead of relying on status alone.

3. VHost discovery

Change the Host header when DNS does not directly reveal virtual hosts.

KALI TERMINAL — VHost

```
ffuf -w [WORDLIST] -u http://[TARGET]/ -H "Host: FUZZ.[DOMAIN]" -fs [BASELINE_SIZE]
```

4. Parameter fuzzing

FUZZ can be the parameter name or the value.

KALI TERMINAL — GET parameter name

```
ffuf -w [PARAMS] -u "http://[TARGET]/page?FUZZ=test" -fs [BASELINE_SIZE]
```

KALI TERMINAL — GET value

```
ffuf -w [VALUES] -u "http://[TARGET]/page?id=FUZZ" -fc 404
```

AUTHORIZED WEB LAB — POST body

```
ffuf -w [VALUES] -u http://[TARGET]/login -X POST -d "username=admin&password=FUZZ" -H "Content-Type: application/x-www-form-urlencoded" -fc 401
```

Note: Credential fuzzing can cause lockouts. Use only when the lab explicitly requires it.

5. Headers / Cookies / Burp

Reproduce the request context used by the application/browser.

KALI TERMINAL — Cookie

```
ffuf -w [WORDLIST] -u http://[TARGET]/FUZZ -b "session=[VALUE]"
```

KALI TERMINAL — Burp proxy

```
ffuf -w [WORDLIST] -u http://[TARGET]/FUZZ -x http://127.0.0.1:8080
```

Use a low thread count when you want to review requests in Burp.

6. Workflow

Step	Action	Reason
1	Baseline	Understand the invalid/default response.
2	FUZZ	Mark exactly what should vary.
3	Wordlist	Choose a list relevant to the target.
4	Filter	Use fc/fs/fw.
5	Verify	Open important results manually.
6	Save	Keep output/evidence when needed.

Prepared as a quick-reference companion to the canonical Arabic guide. Use only in labs or systems you are explicitly authorized to test.

References:

<https://github.com/ffuf/ffuf>

<https://github.com/ffuf/ffuf/wiki>